# المخاطر والحوكمة في زمن اللخبطة

Lecture 2 (Lecture 1 continuation) — Cybersecurity Governance & Risk Management

> **Security management planning** : creating, implementing and enforcing a security policy that **aligns security with the strategy, goals, mission and objectives** of the organization (based on business cases, budget limits and scarce resources).

> **Business case** : a documented argument that defines a **need to make a decision or take action** — often used to justify a new security project.

> **Resource limitations** : money, people, technology and space are limited, so each effort must give the **maximum benefit**.

| Top-down approach | Bottom-up approach |
|---|---|
| **Senior management initiates and defines policy** | **IT staff** make security decisions without senior management |
| **Middle management turns policy into standards, baselines, guidelines, procedures** | Rarely used |
| **Most effective** | Considered **problematic** |

| CIO (Chief Information Officer) | CTO (Chief Technical Officer) |
|---|---|
| **Information is used effectively to meet business objectives** | Equipment and software **work properly** to support business |

## Roles and responsibilities

The best security plan is useless without **senior management approval and commitment**.

| Role | Responsibility |
|---|---|
| **Senior manager** | **Ultimately responsible** for security and assets; signs off all security issues; exercises due diligence and due care; **legally liable** |

| Role | Responsibility |
|---|---|
| **Security professional (InfoSec officer, CIRT)** | Trained engineer who follows senior management's directives; writes and implements policy — **implementer, not decision-maker** |
| **Asset / data owner** | High-level manager who **classifies** information; delegates daily work to the custodian |
| **Custodian** | Operational tasks: implements controls, daily maintenance |
| **User** | Complies with policy, handles data responsibly, reports anomalies/incidents |
| **Auditor** | **Independently verifies** controls, policies and practices for compliance |

| Data owner | Custodian |
|---|---|
| **Decides the classification** | **Implements** the protection |
| **High-level manager** | Operational staff |

> **Due diligence** : the **research, investigation and planning** phase — discovering risks, evaluating third parties, preparing properly. ("**Knowing**")

> **Due care** : the **execution** phase — practical procedures that protect assets, implement policy, and prevent negligence. ("**Doing**")

Developing and implementing a security policy is tangible evidence of senior management's due diligence and due care.

### The policy hierarchy

> **Security policy** : the **top tier** — scope of security, assets to protect, objectives, vision and goals. Types: **organizational**, **issue-specific** (e.g. network service, department), **system-specific**.

> **Standards** : **compulsory** requirements for uniform use of hardware, software, technology and controls.

> **Baselines** : the **minimum level of security** every system must meet before production.

> **Guidelines** : **recommendations** on how to implement standards and baselines (not mandatory).

> **Procedures** : **step-by-step** instructions for performing security operations.

| Document | Mandatory? | Detail level |
|---|---|---|
| **Policy** | Yes | Broadest: what and why |
| **Standard** | **Yes** | Specific required tech/controls |
| **Baseline** | **Yes** | Minimum security per system |
| **Guideline** | **No** (advice) | How to implement |
| **Procedure** | Yes | Most detailed: exact steps |

## Threat modeling

> **Threat modeling** : a **proactive** engineering process during design to anticipate adversary tactics and prioritize defenses.

| Approach | Starts from |
|---|---|
| **Attacker-focused (adversary-centric)** | Who might attack: motivations, goals, capabilities, vectors |
| **Software-focused (system-centric)** | The design, architecture and code: flaws, trust-boundary issues |
| **Asset-focused (asset-centric)** | Critical assets, then every threat to them |

| STRIDE | Definition | Violated property |
|---|---|---|
| **Spoofing** | Impersonating a person, account or system | Authenticity / Confidentiality |
| **Tampering** | Maliciously modifying data or configuration | Integrity |

| STRIDE | Definition | Violated property |
|---|---|---|
| **Repudiation** | Denying an action for lack of proof | Nonrepudiation / Accountability |
| **Information disclosure** | Exposing data to unauthorized parties | Confidentiality |
| **Denial of service** | Degrading or disrupting service | Availability |
| **Elevation of privilege** | Gaining higher permissions than authorized | Authorization / Integrity |

> **Diagramming (DFD)** : drawing the elements of a transaction (users, web server, login process, database) to reveal threats across **trust boundaries, data flows and storage**.

> **Reduction analysis (decomposition)** : breaking a system into subroutines, modules or objects to analyze five concepts.

**Q/ What five concepts does reduction analysis examine ?**

1. **Trust boundaries** — where trust/security level changes.
2. **Dataflow paths** — movement of data between locations.
3. **Input points** — where external input enters.
4. **Privileged operations** — actions needing more than normal rights.
5. **Security stance and approach** — policy foundations and assumptions.

**Q/ How are threats prioritized ?**

1. **Probability × Damage potential**.
2. **Risk matrix / heat map** (3×3: probability Low/Medium/High vs damage High/Medium/Low → HH is the worst).
3. **DREAD**: **D**amage, **R**eproducibility, **E**xploitability, **A**ffected users, **D**iscoverability.

## Risk management

> **Risk management** : identifying what could damage or disclose assets, evaluating it against **asset value and countermeasure cost**, and implementing **cost-effective** solutions to reduce risk to an **acceptable level**.

> **Asset** : anything used in a business process (person, place, thing; tangible or intangible).

**Asset valuation (AV)** : the value given to an asset — importance, cost, non-monetary expenses, productivity impact.

**Threat** : any potential occurrence that may cause an undesirable outcome.

**Threat agent / actor** : an entity that **intentionally** exploits vulnerabilities (attacker, malware, disgruntled employee).

**Threat event** : an accidental or intentional occurrence (fire, system failure, power outage).

**Threat vector** : the **path or means** to the target (email, Wi-Fi, USB drive).

**Vulnerability** : a weakness, or the **absence of a safeguard**.

**Exposure** : being **susceptible** to asset loss because of a threat.

**Risk** : the likelihood that a threat exploits a vulnerability to cause harm — **Risk = Threat × Vulnerability** or **Probability of harm × Severity of harm**.

**Safeguard (countermeasure)** : anything that removes or reduces a vulnerability or protects against threats (reconfiguring or removing risky services counts).

**Attack** : intentional exploitation of a vulnerability — it **doesn't have to succeed** to be an attack.

**Breach** : a **successful** attack — a security mechanism was bypassed.

**Hazard** : a potential source or situation capable of causing harm.

| **Attack** | **Breach** |
|---|---|
| **Attempt to exploit** | **Successful** attempt |
| **May fail** | Mechanism bypassed |

| **Threat agent** | **Threat event** | **Threat vector** |
|---|---|---|
| **Who (intentional actor)** | **What happens** (accidental or intentional) | **How/through what** it reaches the target |

**Q/ What is the cyclical relationship of risk elements ?**

1. **Threats** exploit **vulnerabilities**.
2. Vulnerabilities result in **exposure**.
3. Exposure **is risk**.
4. Risk is mitigated by **safeguards**.
5. Safeguards protect **assets**.
6. Assets are endangered by **threats**.

Summary of Cybersecurity Governance L2: Governance & Risk Management (L1 continued). Built only from the lecture file; check the original slides for anything you're unsure about.